

	A	B	C	D	E	F	G	H
1	Azure Cloud Security Risk Assessment - Executive Summary							
2								
3	Point-in-time GRC simulation GRC-WIN-VM01 NIST CSF 2.0 and CIS Controls v8.1							
4								
5	Metric		Value					
6	Total risks		5					
7	High risks		4					
8	Medium risks		1					
9	Mitigations validated		1					
10								
11	Risk ID		Inherent Score					
12	R-01		16					
13	R-02		15					
14	R-03		12					
15	R-04		10					
16	R-05		9					
17								
18	Score		Rating					
19	1-4		Low					
20	5-9		Medium					
21	10-16		High					
22	17-25		Critical					
23								
24								
25								

Overall inherent posture: MEDIUM-HIGH

Highest risk: R-01 public RDP exposure (16/25)

Validated treatment: NSG source restricted from Any to a trusted IPv4 /32. Residual score: 8/25 (Medium).

Inherent Risk Scores (1-25)

Risk ID	Inherent Score
R-01	16
R-02	15
R-03	12
R-04	10
R-05	9

	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q
1	Risk Register																
2																	
3	Likelihood x Impact 1-4 Low 5-9 Medium 10-16 High 17-25 Critical																
4	Risk ID	Asset	Threat Scenario	Observed Weakness	Likelihood	Impact	Inherent Score	Rating	Current Control	Residual Likelihood	Residual Impact	Residual Score	Residual Rating	Status	Evidence	Owner	Target Date
5	R-01	RDP / NSG	Password spraying or brute-force access against RDP	TCP/3389 initially allowed from Any source to a public IP	4	4	16	High	NSG source restricted to trusted IPv4 /32	2	4	8	Medium	Partially Mitigated	03, 04, 05, 14	Cloud Administrator	Complete
6	R-02	Local administrator	Credential compromise provides full VM control	Enabled azureadmin account is a local Administrator; MFA not demonstrated for this path	3	5	15	High	Strong credential and NLA; further controls planned				Not Assessed	Planned	02, 06, 07	Identity Administrator	30 days
7	R-03	Windows OS	Exploitation or defense impairment	Automatic updates turned off; Tamper Protection and PUA blocking shown disabled	3	4	12	High	Local Windows Security and update mechanisms present				Not Assessed	Planned	08, 11, 12	Endpoint Administrator	30 days
8	R-04	Azure subscription	Privilege misuse or compromise of standing Owner access	One account holds Owner at subscription scope	2	5	10	High	Azure RBAC is available; lab acceptance documented				Not Assessed	Accepted for Lab	13	Subscription Administrator	45 days
9	R-05	Logs and monitoring	Malicious activity is detected late	Local Security logs exist, but Azure alerts and enhanced monitoring are not configured	3	3	9	Medium	Local Windows Security event log				Not Assessed	Planned	09, 10	SOC / Cloud Engineer	30 days

	A	B	C	D	E	F
1	Security Control and Compliance Mapping					
2						
3						
4	Risk	Recommended Safeguard	Control Type	NIST CSF 2.0	CIS Controls v8.1	Implementation Evidence
5	R-01	Restrict administrative ingress; prefer Bastion, VPN/private access, or JIT	Preventive	PR.PS; PR.AA	4.4; 12.2	Evidence 14 shows trusted IPv4 /32
6	R-02	Require MFA for administrative access and centralize authentication	Preventive	PR.AA	6.4; 6.5; 6.7	Planned
7	R-03	Maintain secure endpoint configuration and automated OS patching	Preventive / Corrective	PR.PS	4.1; 7.3	Planned
8	R-04	Apply least privilege, RBAC, separation of duties, and access reviews	Governance / Preventive	GV.RR; PR.AA	5.1; 6.8	Accepted for personal lab; production reduction planned
9	R-05	Centralize guest logs and configure actionable alerts	Detective	DE.CM; DE.AE	8.2; 8.11	Planned

	A	B	C	D	E	F	G	H
1	Risk Treatment Action Plan							
2								
3								
4	Action ID	Risk	Action	Priority	Owner	Target	Success Measure	Status
5	M-01	R-01	Restrict NSG RDP source to trusted IPv4 /32	P0	Cloud Administrator	Immediate	No Any source on TCP/3389; authorized RDP succeeds	Complete
6	M-02	R-01	Replace direct public RDP with Bastion, VPN/private access, or JIT	P0	Cloud Architect	30 days	No continuously exposed public management port	Planned
7	M-03	R-02	Require MFA-capable centralized authentication for administrative access	P0	Identity Administrator	30 days	Administrative access requires MFA where supported	Planned
8	M-04	R-03	Enable automated patch orchestration and compliance reporting	P1	Endpoint Administrator	30 days	Scheduled patching and compliant status	Planned
9	M-05	R-03	Enable Tamper Protection and PUA blocking	P1	Security Administrator	14 days	Windows Security warning states resolved	Planned
10	M-06	R-05	Deploy Azure Monitor Agent and collect guest security events	P1	Cloud / SOC Engineer	30 days	Security events searchable in Log Analytics	Planned
11	M-07	R-05	Configure alert rules and test action-group delivery	P1	SOC Engineer	30 days	Test notification received	Planned
12	M-08	R-04	Review Owner access and implement least-privilege RBAC	P2	Subscription Administrator	45 days	No unnecessary permanent Owner assignment	Planned

	A	B	C	D	E	F		
1	Risk Scoring Guide							
2								
3								
4	Likelihood		Definition					
5	1	Rare		Impact		Definition		
6	2	Unlikely		1	Minimal			
7	3	Possible		2	Minor			
8	4	Likely		3	Moderate			
9	5	Almost Certain		4	High			
10					5	Critical		
11	<i>Risk Score = Likelihood x Impact. Ratings: 1-4 Low, 5-9 Medium, 10-16 High, 17-25 Critical. Justification is required for</i>							
12								